



MODULE 08

Authentication, Authorization & Key Management in OT

Course: Cybersecurity for Embedded & OT Systems

Module 08 Focus: Who can access what, safely and responsibly

Network Segmentation using Zones & Conduits

- Network segmentation is a core safety and resilience control in OT
- Flat OT networks allow faults and incidents to spread rapidly
- Segmentation allows only necessary communication, not blanket blocking
- The Purdue Model helps organize OT systems into logical levels
- Zones group assets with similar security needs
- Conduits define controlled communication paths between zones
- Firewalls and data diodes enforce segmentation boundaries conceptually
- Jump hosts provide secure, controlled vendor and remote access
- Least privilege communication reduces accidental and malicious misuse
- Segmentation improves fault isolation, troubleshooting, and recovery

Structured segmentation enables safer operations by ensuring problems remain local, visible, and controlled.

Why Access Control Matters in OT

Operational Technology systems operate continuously, often for years without interruption. Unlike IT environments where systems restart regularly, OT devices run critical processes that cannot be casually stopped or reconfigured. Many of these systems were designed decades ago, long before modern identity and access management practices emerged as standard.

Incorrect or excessive access in OT environments creates consequences that extend far beyond data breaches. Unauthorized changes can trigger unsafe physical actions, disrupt production lines costing millions per hour, and eliminate the accountability trails needed for incident investigation and regulatory compliance.

Unsafe Actions

Physical harm from improper control

Production Loss

Costly operational disruptions

No Accountability

Cannot trace who did what

Access control in OT is fundamentally about safety and operational integrity, not user convenience.

Identity Challenges in OT Environments

Operational Technology presents unique identity management challenges that differ dramatically from traditional IT systems. These challenges stem from both technical limitations and operational requirements that must be respected.

Legacy Device Constraints

Many OT devices support only a handful of user accounts, sometimes as few as one or two. These systems were designed for simplicity and reliability, not complex user management.

Shared Account Dependencies

Long-lived shared accounts remain common due to device limitations and the need for operational continuity across shifts and teams. While problematic for security, they reflect practical constraints.

Integration Difficulties

OT systems often cannot integrate with enterprise identity platforms like Active Directory or LDAP. Air gaps, network segmentation, and proprietary protocols prevent seamless authentication federation.

Infrequent Credential Changes

Password rotation in OT requires careful planning and coordination. Systems cannot be casually restarted, and credential changes risk disrupting critical processes if not properly tested.

Vendor Dependencies

Many OT systems require vendor involvement for maintenance, updates, and troubleshooting. This creates persistent external access needs that must be carefully managed.

- ❑ These constraints require strong governance frameworks and disciplined procedures, not aggressive technical controls that could compromise system availability.

Why Shared Accounts Are Common (And Risky)

Why They Exist

Device Limitations

Most OT devices support very few user accounts due to embedded system constraints and legacy design decisions.

Operational Simplicity

Operations teams need reliable, uninterrupted access across shifts without complex authentication workflows that could delay emergency responses.

Continuous Availability

Systems must remain online and accessible 24/7. Account lockouts or authentication failures cannot be tolerated in critical operations.

Risks They Create

Zero Accountability

When multiple people use the same credentials, it becomes impossible to determine who performed specific actions during incident investigations.

Investigation Delays

Forensic analysis becomes significantly more complex and time-consuming when actions cannot be attributed to specific individuals.

Delayed Revocation

When someone leaves or changes roles, their access cannot be removed without affecting everyone else using the shared account.

Operational ease must never be allowed to completely hide responsibility gaps. The goal is finding practical solutions that balance both needs.

Authentication vs Authorization

Understanding the distinction between authentication and authorization is critical for implementing effective access controls in OT environments. While both work together, they serve fundamentally different purposes and require different approaches.

Authentication

Who are you?

Authentication establishes and verifies identity. It answers whether the person or system claiming an identity can prove that claim through credentials, certificates, or other verification methods.

- Username and password verification
- Certificate validation
- Multi-factor authentication
- Biometric verification

Authorization

What are you allowed to do?

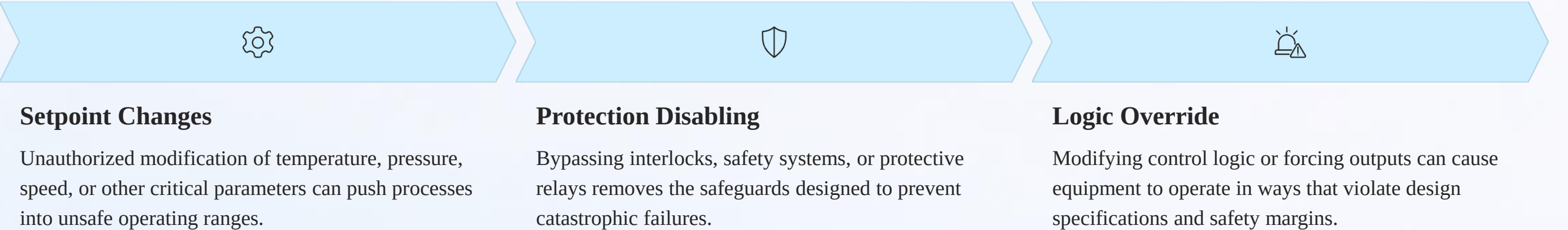
Authorization determines permissions and access rights. It defines what actions an authenticated identity can perform, which resources they can access, and under what conditions.

- Read vs write permissions
- Configuration changes
- Safety override capabilities
- Time-based access restrictions

- ❏ Both authentication and authorization are essential, but **authorization is often more critical in OT** because a verified user with excessive privileges can still cause significant harm.

Why Authorization Is Critical in OT

In Operational Technology environments, knowing *who* someone is matters far less than controlling *what they can do*. A properly authenticated user with inappropriate permissions represents one of the most significant security and safety risks in industrial control systems.



Consider a maintenance technician who needs to calibrate sensors. They require legitimate access to the system for their specific task. However, if that same account can also modify control logic, disable safety interlocks, or change critical setpoints, the risk extends far beyond their actual job requirements.

This principle of least privilege becomes even more critical when vendor accounts, temporary contractors, or emergency responders need access. Each must be carefully scoped to precisely what their role requires—nothing more.

78%

Incidents

Involve excessive privileges

A verified user with too much access is still a safety risk. Authentication confirms identity; authorization protects operations.

Local Accounts in OT Devices

Most OT devices rely on local user accounts stored directly on the device itself. Unlike IT systems that authenticate against centralized directories, these embedded systems maintain their own independent user databases. This approach reflects both the historical development of OT systems and the operational requirements of industrial environments.

Local accounts are managed individually on each device, requiring administrators to manually create, modify, or remove users. Credentials are device-specific, meaning the same username might have different passwords across different PLCs, HMIs, or control systems. This fragmentation makes consistent management challenging but provides important operational benefits.

Benefits of Local Accounts

- **Operational Simplicity:** No dependency on network infrastructure or external authentication services that might fail
- **System Independence:** Devices remain accessible even during network outages or when isolated from enterprise IT systems
- **Minimal Attack Surface:** No integration points with external systems that could be exploited
- **Predictable Behavior:** Authentication mechanisms are straightforward and well-understood by operations staff

Risks of Local Accounts

- **Inconsistent Controls:** Access policies vary across devices, creating security gaps and configuration drift
- **Audit Difficulties:** No centralized view of who has access to what, complicating compliance and risk assessment
- **Password Sprawl:** Users struggle to manage different credentials across dozens or hundreds of devices
- **Delayed Updates:** Removing access when someone leaves requires touching every device individually

□ When local accounts are unavoidable, rigorous documentation and comprehensive logging become absolutely essential compensating controls.

Service Accounts in OT

Service accounts are non-human identities used by applications, automated processes, and system-to-system communications. In OT environments, historians, data collectors, SCADA servers, and integration platforms all require their own authentication credentials to access control systems. These accounts operate continuously, often without human oversight, making their security particularly critical.



Data Historians

Collect and store time-series process data



Integration Services

Bridge OT and IT systems for reporting and analytics



SCADA Servers

Poll devices and aggregate operational information



Backup Systems

Automatically archive configurations and programs

Key Principles for Service Accounts

Minimum Required Privileges

Service accounts should have only the specific permissions needed for their function.
A historian collecting data needs read-only access, never write capabilities.

No Interactive Login

These accounts should never be used for human access or console login. They exist solely for automated system-to-system communication.

Clear Ownership

Every service account must have a designated owner responsible for its security, lifecycle management, and appropriate use.

Documented Purpose

The specific function, required access, and business justification for each service account must be clearly documented and regularly reviewed.

Service accounts should never behave like human users. They require different controls, monitoring, and lifecycle management.

Role Separation in OT

Separating roles and responsibilities is a fundamental security principle that limits the impact of compromised credentials or insider threats. In OT environments, where physical safety is at stake, role separation becomes even more critical. Each role should have carefully defined boundaries that align with actual job responsibilities.



Operator

Monitors system status, acknowledges alarms, and executes pre-approved operational procedures. Operators can view current states and make routine adjustments within normal operating parameters but cannot modify underlying logic or safety systems.



Engineer

Develops and modifies control logic, configures system parameters, and implements design changes. Engineers have broader access but their changes should follow formal change management processes with testing and approval requirements.



Maintenance

Performs equipment repairs, calibration, and preventive maintenance activities. Maintenance personnel need specific access to diagnostic functions and calibration tools but not to operational setpoints or control logic.



IT Support

Manages network infrastructure, cybersecurity tools, and supporting systems. IT staff should not have direct access to control system configurations or the ability to modify process parameters.



Vendor

Provides specialized support, troubleshooting, and system updates under controlled conditions. Vendor access should be temporary, logged, supervised, and restricted to only the specific systems they support.



One account should not do everything. The principle of separation of duties ensures no single individual has complete control over critical systems, reducing both accidental errors and intentional misuse.

Keys and Secrets in OT

Keys and secrets are the foundational elements of trust in OT systems. They authenticate identities, establish secure communications, verify software integrity, and protect sensitive data. Unlike IT environments where secrets can be rotated frequently, OT secrets often persist for years due to operational constraints and device limitations.



Passwords

Traditional authentication credentials used for human and service account access to devices, applications, and systems.



Cryptographic Keys

Symmetric and asymmetric keys used for encrypting communications, protecting data, and establishing secure channels between systems.



Digital Certificates

X.509 certificates that verify system identities, enable TLS/SSL connections, and establish trust relationships in PKI infrastructures.



API Tokens

Bearer tokens and API keys that authorize programmatic access to web services, cloud platforms, and integration endpoints.



Firmware Signing Keys

Private keys used to digitally sign firmware updates, ensuring authenticity and preventing unauthorized code from being loaded onto devices.

Consequences of Compromise

Unauthorized Control

Stolen credentials allow attackers to manipulate industrial processes, change setpoints, or issue commands that could damage equipment or endanger personnel.

Broken Trust

Compromised cryptographic keys undermine the entire security architecture, making it impossible to distinguish legitimate communications from malicious activity.

Malicious Firmware

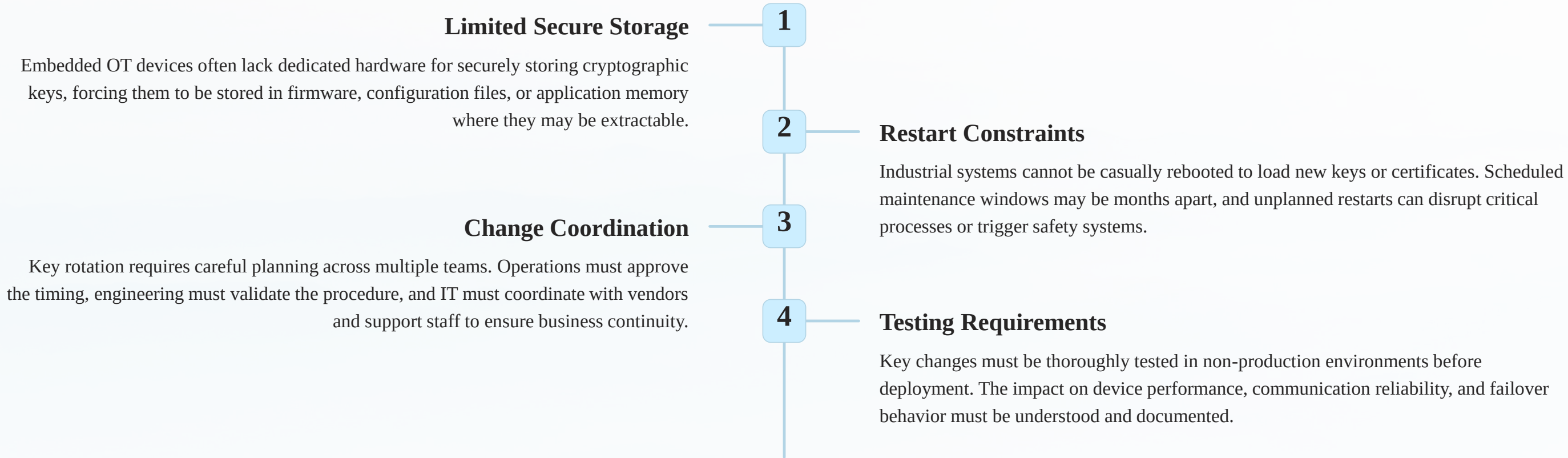
If firmware signing keys are stolen, attackers can create seemingly legitimate updates that install backdoors, disable security features, or brick devices.

Protecting secrets protects physical systems. The security of your OT environment is only as strong as your weakest credential.

Key Management Challenges

Managing cryptographic keys and secrets in OT environments presents unique challenges that don't exist in traditional IT settings. The constraints of embedded systems, the criticality of continuous operation, and the long lifecycle of industrial equipment create a complex environment where standard IT security practices may not apply directly.

Many OT devices lack hardware security modules, trusted platform modules, or secure enclaves for storing cryptographic material. Keys often reside in configuration files, firmware, or even hardcoded in applications. This makes them vulnerable to extraction if an attacker gains access to the device or its backup files.



❑ Security controls in OT must respect uptime requirements and safety considerations. Aggressive key rotation policies that work in IT can create unacceptable operational risks in industrial environments.

Password & Key Rotation (OT View)

Regular credential rotation is a security best practice that limits the window of opportunity for attackers using stolen credentials. However, in OT environments, rotation must be carefully balanced against operational requirements. Poorly planned rotation can cause more harm than the risk it's meant to mitigate.



Planned Scheduling

Credential changes must align with maintenance windows and operational schedules. Avoid rotating keys during peak production, critical processes, or when limited support staff are available.

Coordinate with operations teams to identify appropriate timing.



Complete Documentation

Maintain detailed records of all credentials, their rotation schedule, last change date, and responsible owners. Document the specific steps required for rotation, including any device-specific procedures or vendor requirements.



Thorough Testing

Test rotation procedures in development or staging environments that mirror production. Verify that all dependent systems, applications, and integrations continue functioning after credential changes.

Document rollback procedures in case issues arise.



Team Coordination

Ensure all stakeholders know about planned changes. Operations must understand the schedule, engineering must validate technical procedures, IT security must verify compliance, and vendors must be available for support if needed.

The goal of rotation is reducing long-term risk by limiting credential lifetime. However, rotation done improperly—without testing, coordination, or fallback plans—can create immediate operational risks that outweigh the security benefits. In some OT scenarios, a well-monitored, properly secured static credential may be safer than frequent rotation performed haphazardly.

40%

Incidents

Caused by failed credential updates

Unplanned rotation can be more dangerous than no rotation. Security improvements must never compromise safety or operational stability.



Joiner–Mover–Leaver (JML) Model

The Joiner-Mover-Leaver model provides a structured approach to managing access throughout an individual's lifecycle with an organization. This framework ensures access rights remain aligned with current roles and responsibilities, preventing the accumulation of excessive privileges over time.



Joiner

When someone joins the organization or takes on a new OT role, grant them role-based access appropriate to their responsibilities. Provide only the minimum privileges needed for their specific function. Document the approval chain and business justification.



Mover

When someone changes roles, departments, or responsibilities, review and adjust their access accordingly. Remove permissions no longer needed and add new ones appropriate to their updated role. This prevents privilege accumulation where users retain old access while gaining new access.



Leaver

When someone leaves the organization or no longer requires OT access, remove their access immediately. This includes disabling accounts, revoking certificates, changing shared passwords they knew, and collecting physical access tokens or badges.

Implementation Considerations



Automated Notifications

HR systems should automatically notify OT security teams about employment status changes, role transfers, or terminations to trigger access reviews.



Standardized Procedures

Develop checklists and documented procedures for each JML stage. Include all systems, devices, and accounts that require updates.



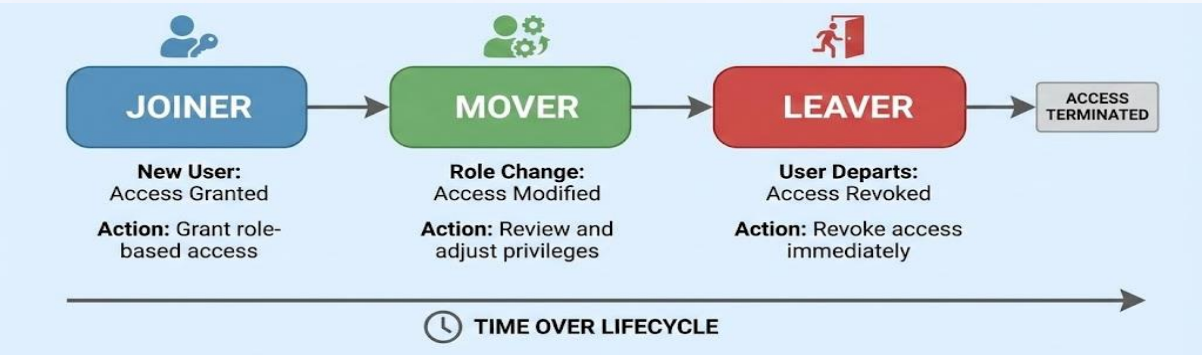
Time-Based Reviews

Even with JML processes, conduct periodic access reviews to catch exceptions, temporary access that became permanent, or process failures.

OT access must follow people, not remain static. Failing to update access as roles change creates unnecessary risk and exposure.

Why JML Is Important in OT

Without disciplined lifecycle management, OT environments accumulate orphaned accounts, forgotten credentials, and excessive privileges that create significant security and safety risks. The consequences extend beyond typical IT concerns because OT access can directly impact physical processes and personnel safety.



Real-World Impact

Consider a control systems engineer who transfers to IT after three years working with PLCs and SCADA systems. Without proper JML processes, they retain engineering credentials with the ability to modify control logic, despite no longer having operational responsibilities. If their IT credentials are compromised, attackers gain both IT access and powerful OT privileges.

Similarly, a vendor who performed a system upgrade six months ago may still have administrative access through accounts that were never disabled. If that vendor experiences a breach or an employee with access credentials leaves their company, your OT environment remains exposed without your knowledge.

Orphaned Accounts

Former employees' accounts remain active long after they've left, providing potential entry points for attackers or allowing unauthorized access by ex-employees who retain credentials.

Persistent Vendor Access

Temporary vendor accounts created for specific projects continue functioning indefinitely, giving external parties ongoing access they no longer need or that isn't properly monitored.

Insider Risk Growth

Current employees accumulate privileges from previous roles, creating opportunities for accidental misconfiguration or intentional misuse by insiders who know systems well.

Compliance Failures

Regulations like NERC CIP, ISA/IEC 62443, and others require demonstrating appropriate access controls. Poor JML processes lead to audit findings and potential penalties.

Lifecycle-based access management reduces hidden exposure by ensuring permissions stay synchronized with actual roles and responsibilities.

Logging and Audit Trails

Comprehensive logging provides the evidentiary foundation for accountability, incident investigation, and regulatory compliance in OT environments. Without detailed audit trails, organizations cannot answer basic questions about who did what, when, and why—leaving them blind to both operational errors and malicious activities.



Evidence Collection

Logs provide the detailed evidence needed to understand what happened during incidents. They capture the sequence of events, commands issued, and system responses that explain unexpected behavior or failures.



Investigation Support

During incident response, logs help teams reconstruct timelines, identify root causes, and determine whether events were accidental or malicious. They're essential for forensic analysis and corrective action.



Accountability Enforcement

When actions are logged and associated with specific identities, individuals understand their activities are traceable. This awareness promotes responsible behavior and reduces both errors and intentional misuse.



Compliance Demonstration

Regulations and standards require demonstrating appropriate access controls and change management. Audit logs provide the evidence auditors need to verify compliance with requirements like NERC CIP, ISA/IEC 62443, and FDA 21 CFR Part 11.

Typical OT Log Sources

Login Attempts

- Successful authentications
- Failed login attempts
- Account lockouts
- Session durations

Configuration Changes

- Parameter modifications
- Logic updates
- Setpoint adjustments
- Security setting changes

Remote Sessions

- VPN connections
- Remote desktop access
- Vendor connections
- File transfers

Access Denials

- Insufficient privileges
- Invalid credentials
- Policy violations
- Blocked commands

❏ Logs must exist and be protected, but log collection must never disrupt operations. Design logging systems with resilience, ensuring log failures cannot affect control system operation.

What Logs Help You Answer

Effective logging transforms abstract security and operational requirements into concrete answers about system activity. When incidents occur, questions arise quickly—and comprehensive logs make the difference between rapid resolution and prolonged uncertainty.



Who accessed the system?

Identify the specific user account, source IP address, and authentication method used for access. Distinguish between human users, service accounts, and automated processes.



What changed?

Document the specific modifications made: which parameters were adjusted, what configuration files were edited, what control logic was uploaded. Capture before and after values when possible.



When did it happen?

Establish precise timestamps for all activities. Correlate events across multiple systems to build comprehensive timelines. Ensure accurate time synchronization across all logging sources.



Was access approved?

Compare actual access attempts against approved change requests, maintenance windows, or standing authorization. Identify unauthorized or suspicious activities that deviate from normal patterns.



Was policy followed?

Verify that actions complied with documented procedures, change management processes, and security policies. Detect policy violations that require corrective action or additional training.

These questions arise during multiple scenarios: investigating production incidents, responding to security alerts, conducting compliance audits, or analyzing system performance. Logs provide objective evidence that removes guesswork and speculation from critical decisions.

92%

Faster

Incident resolution with good logs

Without logs, there is no trustworthy answer. Memory fades, people disagree, and systems don't explain themselves—only logs provide objective truth.

Vendor & Contractor Access Risks

External access by vendors and contractors represents one of the highest-risk scenarios in OT security. While vendor involvement is often necessary for specialized maintenance, troubleshooting, and system updates, it creates significant exposure that must be carefully controlled. The challenge lies in balancing operational necessity with security and safety requirements.

Why Vendor Access Is Necessary

OT systems require specialized knowledge that internal teams may not possess. Equipment vendors understand their products' intricacies, system integrators designed the overall architecture, and software vendors can troubleshoot their applications. Excluding vendors entirely would leave organizations unable to maintain or support critical systems. Emergency situations may require rapid vendor response to restore operations or address safety concerns.

Why It Creates Risk

Vendor access extends your attack surface beyond your direct control. You cannot guarantee vendor cybersecurity practices, employee background checks, or credential management. Compromised vendor credentials provide attackers with legitimate-looking access to your systems. Additionally, vendors may need elevated privileges that far exceed typical user permissions, amplifying the potential impact of any misuse.

Common Problems

Permanent Accounts

Vendor accounts created for specific projects remain active indefinitely, long after the work is complete and the vendor relationship may have ended.

No Session Tracking

Organizations lack visibility into what vendors do during access sessions, including which systems they touch, what changes they make, or what data they view.

Shared Credentials

Multiple vendor technicians use the same login, making it impossible to track which individual performed specific actions or access your systems.

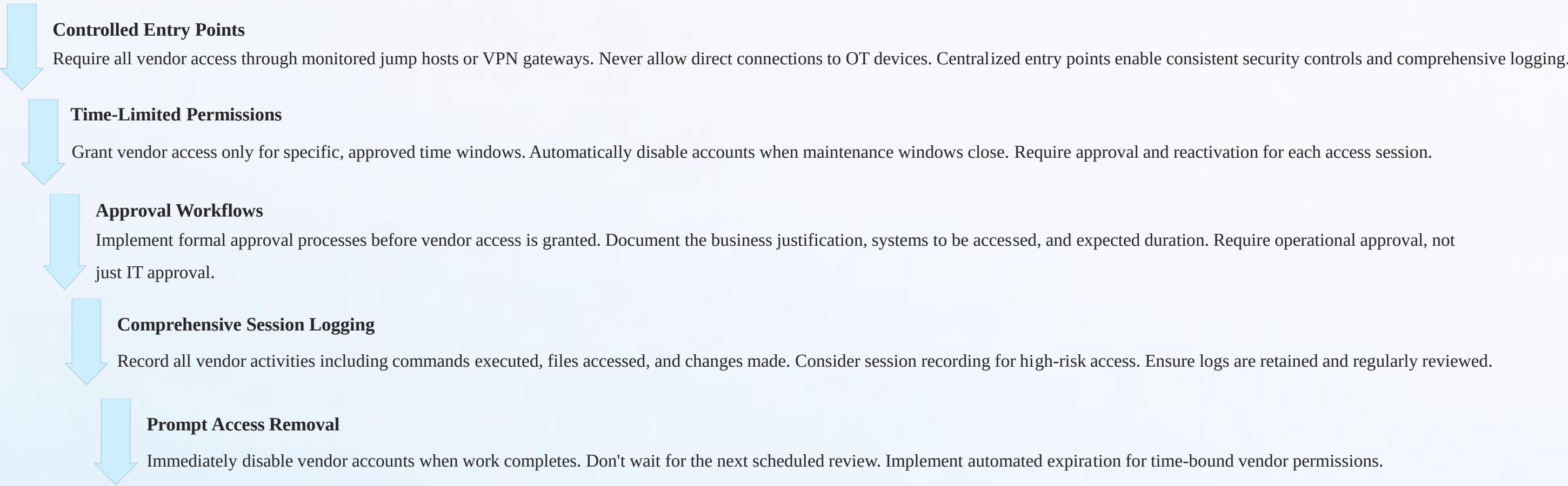
Uncontrolled Entry Points

Vendors connect through various methods—VPNs, remote desktop, direct dial-up—without consistent security controls or monitoring across all paths.

❑ External access must be strictly governed. The convenience of vendor access cannot justify leaving your OT environment persistently exposed to external risk.

Safe Vendor Access Practices

Implementing secure vendor access requires careful governance that balances operational needs with risk management. The goal is enabling necessary vendor work while maintaining visibility, control, and accountability throughout the engagement.



Additional Controls

Supervision Requirements

Consider requiring internal staff presence during vendor sessions for critical systems. This provides real-time oversight and knowledge transfer.

Contractual Obligations

Include cybersecurity requirements in vendor contracts: credential management, incident reporting, and compliance with your security policies.

Regular Reviews

Periodically audit all vendor access accounts, even inactive ones. Verify that permissions still align with current contracts and business needs.

Trust must be verified, logged, and limited. Never assume vendor access is safe simply because they're a known partner.

Module 08 Key Takeaways

- **OT identity management faces unique constraints**

Legacy devices, operational requirements, and safety considerations create challenges that demand governance and discipline rather than aggressive technical controls.

- **Authentication $\neq$ Authorization**

Knowing who someone is matters less than controlling what they can do. Verified users with excessive privileges represent significant safety risks.

- **Shared credentials reduce accountability**

While sometimes operationally necessary, shared accounts eliminate the ability to trace actions to individuals. They require compensating controls like enhanced logging.

- **Role separation limits impact**

Operators, engineers, maintenance, IT, and vendors should have distinctly different access levels aligned with their actual responsibilities.

- **Key management protects foundational trust**

Passwords, cryptographic keys, certificates, and tokens are critical assets. Compromised secrets can enable unauthorized control and break system integrity.

- **JML prevents orphaned access**

Joiner-Mover-Leaver processes ensure access follows people through role changes, preventing privilege accumulation and lingering external access.

- **Logging supports safety and audits**

Comprehensive audit trails provide accountability, enable incident investigation, and demonstrate compliance. Without logs, there are no trustworthy answers.

- **Vendor access requires strict governance**

External access is high-risk but often necessary. Controlled entry points, time limits, logging, and prompt removal are essential controls.

Reflection & Class Discussion

Discussion Topics

- Why identity management in OT is different from IT
- Risks created by shared credentials in control systems
- Why authorization (what you can do) matters more than login alone
- Challenges of managing access in always-on OT environments
- Importance of audit trails and accountability

Homework & Assignments

- Explain the difference between authentication and authorization with an OT example
- List three risks of shared credentials in OT systems
- Identify four OT roles and describe why role separation is important
- Describe the Joiner–Mover–Leaver (JML) model for OT access control
- Explain why vendor access must be time-bound and logged

Applied Learning Task (Optional)

Access Governance Exercise:

- For a small OT setup (PLC, HMI, vendor laptop):
 - Identify who should have access
 - Define allowed actions for each role
 - Specify how access is granted, monitored, and revoked

[→ NEXT MODULE](#)

Module 09

Anomaly Detection Fundamentals for OT Monitoring

Having established who can access OT systems and what they're allowed to do, we now turn our attention to detecting when something abnormal occurs. Module 09 explores the fundamentals of monitoring OT environments for suspicious or unexpected behavior.

You Will Learn



Why anomaly detection matters in OT

Understanding the unique requirements and constraints of monitoring industrial control systems for security threats and operational issues.



Events, logs, and time-series data

Different types of data sources in OT and how they contribute to comprehensive visibility across control systems.



Baselines and thresholds

Establishing normal behavior patterns and defining meaningful deviations that warrant investigation or alerting.



False positives and false negatives

Balancing detection sensitivity with operational noise to create actionable alerts that teams can realistically respond to.



Precision, recall, and alert quality

Measuring detection system effectiveness and continuously improving signal-to-noise ratios in monitoring systems.

Thank you for completing Module 08. Let's continue with Module 09 to explore how we monitor for threats and anomalies in operational technology environments.